

PRODUCT REQUIREMENTS DOCUMENT

Event Networking Platform

A Multi-Tenant PWA for Live Event Contact Exchange & Digital Business Cards

Powered by VIMS Enterprise

Document Version: 1.0 (Draft for Review)

Date: 29 April 2026

Prepared for: Gowthamraj M, VIMS Enterprise

Status: Awaiting Stakeholder Sign-off

1. Executive Summary

This document defines the complete product requirements for an Event Networking Platform — a Progressive Web Application (PWA) designed to digitise the contact-exchange experience at live business and professional events. The platform replaces traditional paper visiting cards with a privacy-first digital alternative that activates the moment an attendee scans the event QR code at the venue.

The system operates on a strict multi-tenant architecture where each event is fully isolated. A super administrator (VIMS Enterprise) governs the platform, event organisers self-onboard to create and manage their own events, and attendees join an event by scanning a unique event-specific QR code. Within each event, attendees build a digital business card, browse other participants by business filters, and exchange contact details only after explicit mutual consent through a connection-request flow. Phone numbers and email addresses are never publicly visible — they reveal only when a request is accepted.

The platform is intentionally not a ticketing or payment product. It is a networking enabler, optimised for in-event use and immediate retention of relationships made on the floor.

1.1 Vision Statement

"Transform every business event into a structured, searchable, privacy-respecting professional network — accessible by a single QR scan at the venue, owned by the organiser, and powered by VIMS Enterprise."

1.2 Core Value Propositions

- For Attendees: No printed cards to carry, no manual contact entry, no spam — connect only with people who consent.
- For Organisers: A live attendee directory, real-time engagement metrics, and a post-event database for follow-up campaigns (DPDP-compliant).
- For VIMS Enterprise: A scalable SaaS platform with multi-event tenancy, branded as "Powered by VIMS Enterprise" on every event page.

1.3 Out of Scope (v1.0)

To keep the v1.0 build focused, the following are explicitly excluded:

- Payment gateway / event ticketing
- In-app real-time chat or messaging between attendees
- Event agenda, schedule, or session management
- Sponsor / exhibitor microsites
- Native iOS / Android applications (PWA covers mobile)
- Advanced AI matchmaking (deferred to v2.0)

2. User Roles & Permissions

The platform has three distinct user roles, each with strictly bounded capabilities. Role separation is enforced at both the application layer and the database layer (row-level security).

2.1 Role Hierarchy

Role	Description & Authority
Super Admin	VIMS Enterprise — platform owner. One single account at the top of the hierarchy. Has visibility across all organisers and all events. Approves data-deletion requests, handles DPDP compliance escalations, and manages platform-level branding.
Event Organiser	Self-signup account that creates and manages one or more events. Each organiser sees only their own events and their own attendees — never any other organiser's data. Receives admin panel for their events.
Attendee (End User)	Person who scans the event QR code at the venue. Creates a profile scoped to that single event. Can attend multiple events; each event creates a separate profile linked to the same email.

2.2 Permission Matrix

Action	Super Admin	Event Organiser
Create event	Yes (any organiser)	No
Approve organisers	Super Admin only	—
Edit own event details	—	Yes
Delete event (with super admin sign-off)	Final approval	Initiate request
View all events platform-wide	Yes	No
Send announcement to attendees	—	Yes (own event only)
Export attendee list to Excel	Yes (any event)	Yes (own event only)
See another attendee's phone/email	—	Only after mutual accept
Edit own profile / business card	—	Attendee yes (own profile only)
Withdraw connection request	—	Attendee, sender side
Final data deletion (DPDP request)	Super Admin only	Cannot delete platform-wide

3. Functional Requirements

3.1 Event Organiser — Self-Signup & Onboarding

1. Organiser visits the public landing page and clicks "Create your event".
2. Self-signup form: full name, organisation, email, mobile, password (min 8 chars, 1 uppercase, 1 number, 1 special).
3. Email verification via OTP (6-digit, 10-minute validity).
4. Upon verification, organiser lands in the Organiser Dashboard with zero events created.
5. Optional: Super Admin may switch on "manual approval" mode in the future. v1.0 = automatic activation after email OTP.

3.2 Event Creation

Each event is created from the Organiser Dashboard via a guided form. The form is broken into four steps:

Step 1 — Event Basics

- Event name (mandatory, 3–80 chars)
- Event description (mandatory, max 500 chars)
- Event start date & time (mandatory)
- Event end date & time (mandatory; must be after start)
- Venue / address (mandatory, free text + optional Google Maps link)
- Expected attendee count (numeric, used for capacity planning)

Step 2 — Branding (White-Label)

- Event logo upload (PNG/JPG, max 2 MB, recommended 512×512 px)
- Primary brand colour (hex picker)
- Secondary brand colour (hex picker)
- Banner image (optional, 1600×600 px recommended)
- All registration / login pages for this event will render in the chosen brand colours. The platform-level footer always shows "**Powered by VIMS Enterprise**" — non-removable.

Step 3 — Attendee Form Fields

Organiser confirms which profile fields are required vs optional for this specific event. Default schema:

Field	Default	Notes
First name	Mandatory	Always required
Last name	Mandatory	Always required
Email	Mandatory	Used for OTP login + future communication

Field	Default	Notes
Phone (mobile)	Mandatory	Hidden until connection accepted
Designation	Mandatory	Shown on business card
Company	Mandatory	Shown on business card
Business type	Mandatory	Used in search filters
Industry	Mandatory	Used in search filters
Services offered	Mandatory	Free text + tag chips, used in search
Location (city)	Mandatory	Used in search filters
Address (full)	Optional	Hidden by default, revealed on accept
Company size	Optional	Dropdown: 1-10, 11-50, 51-200, 201-500, 500+
Tags (free)	Optional	Up to 10 tags, used in search
Profile photo	Optional	Recommended for recognisability
Company logo	Optional	Shown on business card

Step 4 — Event Rules

- Maximum connection requests per attendee: configurable, default UNLIMITED (per your spec — no limits)
- Whether attendees can see address after acceptance (default: yes)
- Whether attendees can download other attendees' vCards after acceptance (default: yes)

3.3 QR Code Generation & Distribution

Upon clicking "Publish Event", the system generates a unique, immutable QR code for the event.

- Each QR code encodes a unique URL: `https://app.vims-events.com/e/{eventSlug}-{shortHash}`
- Short hash (8 chars) ensures URLs are not guessable / enumerable across events.
- Event slug is auto-generated from event name + number suffix if duplicate.
- QR code is downloadable as PNG (300 DPI, print-ready) and SVG (vector).
- Organiser can re-download the QR code anytime from the Event Detail screen.
- QR code does NOT change for the lifetime of the event — print once, use throughout.

Critical isolation rule: A QR code from Event A, when scanned, can NEVER allow login to Event B. The URL hash is bound to the event's tenant ID and is validated server-side on every request.

3.4 Attendee Registration & Login Flow

3.4.1 First-time Registration (Scan → Register)

6. Attendee scans the event-specific QR code displayed at the venue (banner, registration desk, lanyard).
7. Phone camera opens a browser tab → loads the event's branded registration page.
8. Page shows event banner, name, date, and the message "Welcome to {Event Name} — create your digital card to start networking."
9. Attendee chooses "Register" (or "I'm already registered" → goes to OTP flow).
10. Registration form renders fields per event configuration (Section 3.2 Step 3).
11. On submit, system sends 6-digit OTP to the entered email.
12. Attendee enters OTP → profile is created → digital business card auto-generates → user lands in attendee directory.
13. PWA install prompt appears: "Add to home screen for quick access during the event."

3.4.2 Returning Login (Same Event)

14. Attendee re-scans QR code OR opens PWA from home screen.
15. System detects existing email → sends OTP → attendee enters OTP → logged in.
16. No password ever — passwordless OTP is the only auth path for attendees.

3.4.3 Same Person, Different Event

If the same person (same email) attends Event A and later Event B run by a different organiser, they must register separately for Event B with a fresh profile. Profiles are NOT carried across events. This is by design — multi-tenant isolation overrides convenience. The user's email is the only data point that exists in both tenants, and it is hashed for cross-event analytics only at the super-admin level.

3.5 Digital Business Card

Generated automatically from the attendee's profile. Visible to the attendee in their "My Card" tab.

3.5.1 Card Display Elements

- Profile photo (or initials avatar if not uploaded)
- Full name + designation
- Company logo (or company name in styled type)
- Company name
- Business type / industry chip
- Top 3 services (rest accessible via "View all")
- City / location
- Card-specific QR code that, when scanned in person by another attendee, triggers an instant connection request
- "Powered by VIMS Enterprise" footer (small, non-removable)

3.5.2 vCard (.vcf) Download

- Attendees can download their own vCard at any time.
- After a connection request is accepted, the requesting party gains access to download the other person's vCard.
- vCard format: vCard 3.0, includes FN, ORG, TITLE, EMAIL, TEL, ADR, URL, PHOTO (base64), and X-CUSTOM fields for industry & tags.
- vCard saves directly into the user's native phone contacts on tap (iOS / Android).

3.6 Attendee Directory & Search

After login, the attendee's home screen is the Directory — a scrollable list of all other attendees in the same event.

3.6.1 Public Profile Card (List View)

Each card in the directory shows ONLY public information:

- Profile photo / initials
- Name + designation
- Company + business type
- City
- Top 2 services as chips
- "Connect" button (changes state: Connect → Pending → Connected)

Phone number, email address, and full address are NEVER visible at this stage.

3.6.2 Search & Filters

Search bar at the top supports free-text search across name + company + services.

Filter chips (multi-select where applicable):

- Business Type (dropdown of all types present in this event)
- Industry (dropdown)
- Location / City (dropdown of all cities)
- Services (multi-select tag picker)
- Company size (multi-select)
- Tags (free-tag picker)

Filters combine with AND logic. Search results update live as user types/selects.

3.7 Connection Request Flow

3.7.1 Sending a Request

17. User A taps "Connect" on User B's directory card.
18. Optional: User A may add a 200-character message ("Met you at the keynote, would like to discuss your tooling stack").
19. Request is created in DB with status = PENDING, timestamp, sender_id, receiver_id, optional_message, event_id.
20. User B receives: (a) in-app notification badge, (b) email notification with sender's name + business + message.
21. User B sees the request in their "Requests" tab — showing sender's name, designation, company, business type, city, and message.
22. User B's view does NOT yet show sender's phone or email.

3.7.2 Receiver Actions

- Accept → status becomes CONNECTED. Both parties can now see each other's phone, email, and full address. Both parties get a notification (in-app + email). Both can download each other's vCard.
- Decline → status becomes DECLINED. Sender sees their request remains in "Sent" with status "Declined" (no notification to avoid social friction). Sender can re-send only after 24 hours.
- Ignore → request remains PENDING indefinitely; no auto-expiry in v1.0.

3.7.3 Sender Actions

- Withdraw — at any time before the receiver accepts/declines, the sender can withdraw the request. Status becomes WITHDRAWN; the request disappears from the receiver's pending list. Receiver receives no notification.
- If withdrawn, the sender can re-send a fresh request immediately (no cooldown).

3.7.4 No Limits

Per your spec, there is no upper bound on requests sent or connections made within an event. The system does, however, log a counter visible to the organiser admin panel for engagement analytics.

4. Admin Panel — Event Organiser View

Each event organiser sees a dashboard scoped strictly to their own events. The dashboard is the operational cockpit during the live event and the analytics review tool after.

4.1 Dashboard Home

- Card: Total events created
- Card: Active events (those whose end date has not passed)
- Card: Total registered attendees across all own events
- Card: Total connections made across all own events
- List: All events with status (Upcoming / Live / Ended), QR re-download, edit, delete (subject to super admin)

4.2 Event Detail Screen

4.2.1 Live Stats (auto-refresh every 30s during event window)

- Live attendee count (registered)
- Connection requests sent (total)
- Connection requests accepted (total)
- Acceptance rate (%) — engagement quality metric
- Active users in last 5 minutes (real-time pulse)

4.2.2 Attendee List

- Searchable, sortable table of all registered attendees
- Columns: Name, Company, Designation, Business Type, City, Registered At, # Connections Made
- Per-row action: View profile (read-only), flag as inappropriate
- Bulk action: Export to Excel (.xlsx) — see 4.4

4.2.3 Announcement Broadcasting

- Compose announcement (title + body, max 500 chars + optional URL)
- Send to all registered attendees of this event
- Delivery channels: in-app push (PWA notification) + email
- History log of all announcements sent (timestamp, delivery count, open count)

4.2.4 Event Settings

- Edit branding (logo, colors)
- Edit event details (name, description, venue) — date changes restricted to before event start
- Re-download QR code (PNG / SVG)
- Request event deletion → routed to Super Admin for final approval

4.3 Notifications Inbox

- New attendee registered
- Suspicious activity flag (e.g., 50+ requests sent in 1 minute by one attendee — anti-spam)
- Super Admin notice / system maintenance

4.4 Excel Export

Organiser-initiated export produces an .xlsx file with the following sheets:

- Sheet 1: Attendees — all profile fields (including phone & email, since organiser legitimately owns the data)
- Sheet 2: Connections — pairs of attendees who connected, with timestamp
- Sheet 3: Engagement Summary — per-attendee count of requests sent / received / accepted
- Sheet 4: Announcement Log

All exports are logged with timestamp, exporter ID, and IP for DPDP audit trail.

5. Super Admin Panel — VIMS Enterprise

Single, privileged account. Visibility across all organisers and all events platform-wide. Designed for governance, not day-to-day operations.

5.1 Capabilities

- View list of all event organisers (with sign-up date, # events, # total attendees)
- Suspend or reactivate an organiser account
- View list of all events platform-wide with cross-event search
- Approve or reject organiser-initiated event-deletion requests
- Hard-delete an event and all associated data (DPDP fulfilment)
- Process attendee data-deletion requests (DPDP Article — Right to Erasure)
- Set platform-wide announcement (rare, e.g., scheduled maintenance)
- View platform analytics: total events, total attendees, total connections, active organisers
- Configure platform settings: email templates, OTP validity, branding lock-down, terms of service

5.2 Event Deletion Workflow

23. Organiser raises deletion request from their event settings.
24. Super Admin receives notification with reason.
25. Super Admin reviews — can preview the data that will be lost.
26. Super Admin approves or rejects with note.
27. On approval: event marked DELETED in DB. Attendee personal data is purged within 30 days.
Anonymised aggregate stats may be retained for platform analytics.
28. On rejection: organiser is informed with the reason. Event remains active.

6. End-to-End User Flows

6.1 Flow A — Organiser Creates an Event

29. Lands on landing page → clicks "Create your event"
30. Self-signup form → email OTP verification → enters dashboard
31. Clicks "+ New Event" → 4-step wizard
32. Step 1 Basics → Step 2 Branding → Step 3 Fields → Step 4 Rules → Preview → Publish
33. System generates unique QR code → organiser downloads PNG and SVG
34. Organiser prints QR on banner / lanyard / desk standee for the venue

6.2 Flow B — Attendee Registers via QR Scan

35. Walks into venue → sees event banner with QR code
36. Opens phone camera → points at QR → taps the URL preview
37. Mobile browser opens branded registration page
38. Fills profile fields → submits → receives OTP via email
39. Enters OTP → digital business card generated → lands in attendee directory
40. Browser prompts: "Add to home screen?" → user installs PWA

6.3 Flow C — Attendee A Connects with Attendee B

41. A opens directory → applies filters (e.g., Industry: Automotive, City: Chennai)
42. A views B's public card (no phone, no email visible)
43. A taps Connect → optionally adds message → submits
44. B receives in-app notification + email
45. B opens Requests tab → sees A's name, company, business type, message
46. B taps Accept
47. Both A and B receive in-app + email confirmation
48. A and B can now see each other's phone, email, full address
49. Either can tap "Save to phone" → vCard downloads → native contacts app opens → Save

6.4 Flow D — Organiser Sends Announcement During Event

50. Organiser opens Event Detail → Announcements tab
51. Composes title + body (e.g., "Lunch is now served at Hall 2")
52. Clicks Send → confirmation modal → confirms
53. System dispatches: in-app push to all PWA-installed attendees + email to all registered emails
54. Delivery report appears within 60 seconds

7. Data Model (Logical)

The platform uses a multi-tenant relational schema. Every attendee, connection request, and announcement carries an event_id, and database-level row-level security (RLS) policies enforce that no query can ever read across tenants. Key entities below.

7.1 Core Entities

Entity	Key Fields	Notes
super_admins	id, email, password_hash, last_login, mfa_enabled	Single seed row for VIMS Enterprise
organisers	id, name, organisation, email, password_hash, mobile, created_at, status (active/suspended), email_verified_at	Self-signup; one organiser owns many events
events	id, organiser_id, slug, short_hash, name, description, start_at, end_at, venue, expected_count, brand_logo_url, brand_primary, brand_secondary, banner_url, qr_url, status (draft/published/deleted), created_at	Tenant unit. All other tables FK to event_id
event_field_config	id, event_id, field_key, is_required, is_visible	Per-event customisation of profile fields
attendees	id, event_id, first_name, last_name, email, phone, designation, company, business_type, industry, services (jsonb), city, address, company_size, tags (jsonb), profile_photo_url, company_logo_url, registered_at, last_active_at	One row per (email, event) pair. Same person at two events = two rows
connection_requests	id, event_id, sender_id, receiver_id, status (pending/accepted/declined/withdrawn), message, created_at, responded_at	All inter-attendee requests
announcements	id, event_id, organiser_id, title, body, link_url, sent_at, recipient_count, opened_count	Broadcast log
audit_logs	id, actor_id, actor_role, action, entity_type, entity_id, ip, user_agent, created_at	Append-only DPDP audit trail
data_deletion_requests	id, requester_email, event_id (nullable), reason, status, requested_at, processed_at, processed_by	DPDP Right-to-Erasure queue

7.2 Tenancy & Isolation

- Every read query is scoped: WHERE event_id = :current_event_id (enforced via RLS, never application-level only)
- Organiser queries are doubly scoped: WHERE event_id IN (SELECT id FROM events WHERE organiser_id = :current_organiser_id)

- Super Admin bypass is logged in audit_logs for every cross-tenant read
- Database backups are encrypted at rest (AES-256) and retained 30 days

8. Non-Functional Requirements

8.1 Performance & Scale

Metric	Target
Concurrent attendees per event	300–500 (current); architecture validated to 5,000 per event for headroom
Concurrent live events	2–3 currently; platform must support 50+ in parallel
Page load time (3G mobile)	≤ 2.5 seconds for directory list of 500 attendees
API p95 latency	≤ 300 ms for read queries
Search query response	≤ 500 ms across 500 attendees with 5 filters applied
OTP delivery time	≤ 30 seconds in 95% of cases
Live stats refresh	30-second polling on organiser dashboard during event window

8.2 Security

- All traffic over HTTPS (TLS 1.3)
- Passwords hashed with bcrypt (work factor ≥ 12)
- OTPs are 6-digit, single-use, 10-minute TTL, rate-limited (max 3 per email per hour)
- CSRF protection on all state-changing endpoints
- Rate limiting: 100 req/min per IP for public endpoints, 1000/min authenticated
- Anti-spam: if an attendee sends >50 connection requests in 1 hour, account is auto-paused pending organiser review
- All admin actions logged in audit_logs (immutable)

8.3 Privacy & Compliance

The platform is designed to comply with India's Digital Personal Data Protection Act 2023 (DPDP) and to align with GDPR principles where applicable to international attendees.

- Lawful basis: consent — captured at registration with explicit checkbox
- Purpose limitation: data used only for networking within the specific event
- Storage minimisation: attendee data retained for 12 months post-event by default; organiser may extend with attendee re-consent
- Right to access: attendees can download their own data as JSON anytime
- Right to erasure: attendees can request deletion → routed to Super Admin → fulfilled within 30 days
- Data ownership post-event: organiser AND super admin both retain copies under joint controllership; attendee retains right to erasure against both

- Privacy policy and terms shown before registration; consent logged with timestamp

8.4 Accessibility

- WCAG 2.1 Level AA compliance
- All interactive elements keyboard-navigable
- Colour contrast ratio $\geq 4.5:1$ for text
- Screen reader friendly (semantic HTML, ARIA labels)
- Touch targets ≥ 44 px (mobile-first design)

8.5 Availability

- Target uptime: 99.5% (excluding scheduled maintenance)
- During active event windows, target 99.9%
- Scheduled maintenance only outside any active event window
- Database point-in-time recovery up to 7 days

9. Recommended Technology Stack

The following stack is optimised for: (a) PWA-first delivery, (b) multi-tenant security, (c) low operational cost at current scale, (d) clean upgrade path to higher concurrency.

9.1 Frontend

Layer	Choice & Rationale
Framework	Next.js 14 (App Router) — React 18 with built-in PWA support via next-pwa
Styling	Tailwind CSS + shadcn/ui component library for accessibility-first primitives
State management	TanStack Query for server state, Zustand for local UI state
PWA service worker	Workbox-driven, with offline shell + cached directory pages
QR generation (client side)	qrcode.react for in-app card QRs
QR scanning	html5-qrcode or @zxing/browser (in-browser, no native app needed)
vCard generation	vcards-js or custom serialiser

9.2 Backend

Layer	Choice & Rationale
API framework	Node.js + NestJS (TypeScript-first, modular, opinionated) OR FastAPI (Python) if team prefers
Database	PostgreSQL 16 with Row-Level Security policies for tenant isolation
ORM	Prisma (Node) or SQLAlchemy 2.0 (Python)
Authentication	Custom OTP service via Resend/SendGrid for email; JWT access tokens (15 min) + refresh tokens (7 days)
Object storage	AWS S3 or Cloudflare R2 for profile photos, logos, banners
Notifications	Web Push (VAPID) for in-app, Resend / AWS SES for email
QR generation (server)	qrcode npm package or qrcode (Python)
Excel export	exceljs (Node) or openpyxl (Python)

9.3 Infrastructure

Layer	Choice
Hosting (frontend)	Vercel (Next.js native) — automatic PWA edge caching
Hosting (backend)	AWS ECS Fargate OR Railway / Render for simpler ops at current scale
Database hosting	Neon, Supabase, or AWS RDS (PostgreSQL with read replicas at scale)
DNS + WAF	Cloudflare (free tier sufficient initially)
Monitoring	Sentry (errors) + Better Stack / Grafana Cloud (uptime, logs)
CI/CD	GitHub Actions

9.4 Stack Cost Estimate (current scale: 3 events × 500 attendees)

- Vercel Pro: ~₹2,000/mo
- Database (Supabase Pro / Neon): ~₹2,000/mo
- Backend (Railway / Render): ~₹1,500/mo
- Email (Resend, ~10k emails/mo): ~₹1,500/mo
- S3 / R2 storage: ~₹500/mo
- Cloudflare: free tier
- Estimated total: ₹7,000–9,000/mo at current scale

9A. Backend Database — Provisioned Configuration

The production backend database has been provisioned on Neon (serverless Postgres). This section captures the connection metadata so engineering can wire the application without ambiguity. The actual password is held in the team's secrets manager (or in the Neon Console) and is NEVER embedded in this document, in source code, or in any shared file.

9A.1 Provider & Environment

Attribute	Value
Provider	Neon (serverless PostgreSQL)
Cloud region	AWS us-east-1
Database engine	PostgreSQL 16 (Neon-managed)
Connection mode	Pooled connection (PgBouncer-style pooler hostname)
TLS	sslmode=require (mandatory)
Channel binding	channel_binding=require (mandatory — prevents MITM credential theft)
Environment	Production (single-tenant Neon project, multi-tenant via Postgres RLS at the schema level)

9A.2 Connection Parameters

Parameter	Value
Host	ep-shy-frog-am8fc2il-pooler.c-5.us-east-1.aws.neon.tech
Database name	neondb
Default role / username	neondb_owner
Password	Stored in secrets manager — NOT in this document
Required query params	sslmode=require, channel_binding=require

9A.3 Connection String Template

Engineers should construct the live connection string by injecting the password from the secrets store at runtime. The shape of the string is:

```
psql 'postgresql://neondb_owner:<PASSWORD>@ep-shy-frog-am8fc2il-pooler.c-5.us-east-1.aws.neon.tech/neondb?sslmode=require&channel_binding=require'
```

Replace <PASSWORD> with the value retrieved from Neon Console → Connection Details, or from the team's secrets manager (recommended environment variable: DATABASE_URL).

9A.4 Application Wiring (Recommended Pattern)

- Set DATABASE_URL as an environment variable on the application server (Vercel env vars, AWS Parameter Store, Doppler, or 1Password Connect)
- Application reads process.env.DATABASE_URL at boot — never hardcode
- For Prisma: schema.prisma uses url = env("DATABASE_URL") — Prisma handles SSL automatically
- For pgcat / pg / node-postgres: pass the connection string directly to the client constructor
- For migrations: use a separate DATABASE_URL_DIRECT (unpooled connection) since some migration tools require direct connections

9A.5 Security Operating Procedure

- **Credential rotation:** Rotate the neondb_owner password every 90 days and immediately if any developer offboards or if the credential is suspected of exposure (e.g., accidentally pasted into a chat, email, or document).
- **No credentials in documents:** Connection strings with live passwords must never be embedded in PRDs, design docs, README files, screenshots, Jira tickets, or shared chat logs.
- **Least-privilege roles:** neondb_owner is the superuser role; create dedicated lower-privilege roles (app_read, app_write, app_admin) for the application layer. The application should NOT connect as neondb_owner in steady state.
- **RLS enforcement:** Every tenant-scoped table (events, attendees, connection_requests, announcements) must have Row-Level Security policies enabled. The application sets a session variable (app.current_organiser_id or app.current_event_id) that policies reference.
- **Audit & backups:** Neon provides point-in-time restore for the last 7 days on the Pro plan; verify the project is on Pro tier before going live. Take logical backups (pg_dump) weekly to S3/R2 for an extra recovery layer.
- **Network:** Neon's pooled endpoint is publicly reachable but TLS-protected. Optionally restrict via Neon's IP Allow list to only the application's egress IPs once the deployment infrastructure is finalised.

9A.6 Required Action Item

ACTION REQUIRED: The connection password was shared in plaintext during the requirements gathering session. Treat it as compromised. Before the application goes live, the neondb_owner password must be rotated via Neon Console → Settings → Reset password. The new password is to be stored only in the team's secrets manager.

10. Phased Build Plan

Recommended delivery in three phases to de-risk the live event use-case and ship value incrementally.

10.1 Phase 1 — MVP (Weeks 1–6)

Goal: Run a live event end-to-end with QR scan, registration, directory, connection requests, and contact reveal. Must be production-grade, not a prototype.

- Auth: OTP for attendees, password+OTP for organisers
- Event creation (basics + branding only — field config and rules use defaults)
- Unique QR code generation + download (PNG, SVG)
- Attendee registration via scanned QR
- Auto-generated digital business card
- Attendee directory with search + 4 filters (Business Type, Industry, City, Services)
- Connection request: send / accept / decline / withdraw
- Phone & email reveal post-acceptance
- vCard download
- In-app notifications + email
- Organiser dashboard: live attendee count, attendee list, Excel export
- Super Admin: organiser list, event list, audit log view
- PWA installable on iOS + Android
- DPDP-compliant consent capture

10.2 Phase 2 — Operational Polish (Weeks 7–10)

- Per-event field configuration (the full Step 3 wizard)
- Announcement broadcasting
- Additional filters: Company Size, Tags
- Delivery reports for announcements
- Anti-spam protections + flag/report
- Event-deletion workflow with super admin approval
- Right-to-Erasure self-service
- Data export (JSON) for attendees
- Audit log search + filter for super admin

10.3 Phase 3 — Scale & Insight (Weeks 11–14)

- Performance hardening (read replicas, edge caching, list virtualisation)
- Advanced analytics dashboard for organisers (engagement heatmaps, peak activity hours)
- Card-to-card scan: scan another attendee's card QR for instant connection

- Bulk-import attendee list (organiser pre-registers known attendees)
- Cross-event "My Networks" view for repeat attendees (with explicit opt-in)
- Multi-language support (English + Tamil + Hindi)

11. Risks & Mitigations

Risk	Likelihood	Mitigation
Venue Wi-Fi unreliable during event	High	PWA offline shell caches directory; OTP fallback via SMS in v2; instruct organiser to ensure Wi-Fi capacity for expected count
Email OTP delayed → registration friction	Medium	Use transactional email provider (Resend/SES) with 99.9% delivery SLA; show resend button after 30s; allow organiser to whitelist domains
Connection request spam by one attendee	Medium	Rate limit at 50 req/hour per attendee; auto-pause + organiser review
Cross-event data leak (critical)	Low (if RLS implemented correctly)	Database-level RLS policies; security audit before launch; penetration test
DPDP non-compliance	Medium	Legal review of consent flow + privacy policy; appoint Data Protection Officer (Super Admin role); document RoPA
QR code printed wrong / unreadable	Medium	Test print before event; provide both PNG (raster) and SVG (vector) formats; include human-readable URL below QR
Same person attempts to register twice in same event	Low	Email is unique key per event; second attempt routes to OTP login
Organiser deletes event with active attendees	Medium	Two-step approval (organiser request → super admin approve); 30-day soft delete window
PWA install on iOS limitations	Low	iOS PWA support is functional but limited; provide clear install instructions; ensure core flows work in Safari without install

12. Glossary

Term	Meaning
PWA	Progressive Web App — a website that can be installed on a phone home screen and works offline, no app store required
Multi-tenant	Architecture where one platform serves many isolated customers (events) with strict data separation
RLS	Row-Level Security — PostgreSQL feature that enforces tenant isolation at the database level
vCard (.vcf)	Standard contact card file format that imports directly into phone contacts
OTP	One-Time Password — single-use 6-digit code sent via email for authentication
DPDP	Digital Personal Data Protection Act 2023 (India)
GDPR	General Data Protection Regulation (European Union)
WCAG	Web Content Accessibility Guidelines
VAPID	Voluntary Application Server Identification — protocol for web push notifications
JWT	JSON Web Token — used for stateless API authentication

13. Sign-Off

This document is the agreed product specification for v1.0 of the Event Networking Platform. Any change to scope after sign-off requires a written change request and may impact timeline and budget.

Role	Signature & Date
Approved by (Product)	_____ Date: _____
Approved by (VIMS Enterprise)	Gowthamraj M Date: _____
Reviewed by (Engineering Lead)	_____ Date: _____

— End of Document —

Powered by VIMS Enterprise